CredPivot

产品需求与技术架构设计 V1.0

产品 / 设计 / 架构 / 安全实施基线

2026-10-15

文档状态：V1.0 设计基线 · 产品暂定名称：CredPivot（密枢） · 适用读者：产品、设计、客户端、密码学、QA 与安全审计人员

本文整合已确认的需求与技术决策。涉及密码学字节级细节、第三方平台权限、应用商店审核和同步存储兼容性的部分，均要求在编码前完成独立设计审查及测试向量验证。文中性能指标为拟定验收目标，非已测量结果。

目录

1. 产品愿景、边界与设计原则
2. 已确认的关键决策
3. 产品范围、用户画像与优先级
4. 统一账号与凭据数据模型（参考 CXF）
5. 密码管理器功能规格
6. MFA 管理功能规格
7. SSH 管理功能规格
8. 三模块联动与核心用户旅程
9. 跨平台交付与浏览器扩展
10. 现代化 UI 与交互设计规范
11. 系统分层架构与工程选型
12. SQLCipher 本地持久化与 Vault 目录
13. 密钥体系、加密与恢复
14. OVB1 开放加密交换格式
15. 快照 + 增量同步协议
16. WebDAV 与可扩展存储适配器
17. Git 单向备份与灾难恢复
18. 安全威胁模型与隐私设计
19. 非功能要求与可维护性
20. 研发实施计划、质量门禁与验收
21. 风险清单与待实现前评审事项

附录 A. 数据结构与接口示例

附录 B. 标准、公开规范与参考资料

01. 产品愿景、边界与设计原则

1.1 产品定义

CredPivot 是一个**离线优先、本地拥有、开放可恢复、端到端加密**的统一凭据管理器，面向希望同时管理网站账号、MFA 验证材料、SSH 密钥及开发者秘密的个人用户和开发者。默认不要求创建 CredPivot 云账户，也不要求运行自建 CredPivot 服务端。

统一入口不是把三个功能放到三个独立菜单中，而是通过一个 *Account / Item* 聚合实体，将同一服务的登录密码、TOTP、SSH Key、备用恢复码、服务器等建立可追踪的关系。例如 GitHub 工作账号在网页登录时推荐密码及 TOTP，在终端 SSH 操作时使用与该账号关联的密钥。

1.2 目标

- 在 macOS、Windows、Android、iOS 与主流浏览器中提供一致的凭据体验，遵循各系统的安全权限边界。
- 持久化 Vault 数据采用加密存储；云同步方只能取得密文与最少量的协议元数据。
- 以一个主密码解锁 Vault，提供独立高熵恢复密钥及设备级生物识别快捷解锁。
- 本地持久化统一使用 SQLCipher；云端数据不依赖 SQLite 数据库文件格式。
- WebDAV 双向同步采用开放加密快照 + 增量变更；未来增添 S3、Google Drive 等仅需新增适配器。
- 浏览器扩展必须依赖本机 CredPivot 应用，不支持独立保险库、独立同步或单独运行。
- Git 仅提供初始化、单向 Push 加密备份及恢复入口，不承担多设备同步职责。
- 用户可保存完整数据副本；第三方实现可依据公开协议和主密码在脱离原 App 的情况下恢复数据。
- UI 采用现代跨平台交互体系，兼顾高频操作效率、可访问性与安全敏感操作的明确反馈。

1.3 非目标（V1 不做）

- CredPivot 中心账号体系、厂商托管密钥或服务端代用户解密。
- Git Pull/Merge 双向数据同步；多个云后端同时可写的多主同步。
- 团队共享保险库、企业后台、组织级策略下发、紧急访问授权。
- 允许浏览器扩展脱离本地 App 自建加密数据库或独立同步。
- 声称能够绝对防御弱主密码的离线暴力猜测、已完全控制用户设备的恶意软件或历史备份中的旧秘密泄露。

1.4 设计原则

1. **数据所有权**：用户拥有完整加密文件；迁移不依赖厂商在线服务。
2. **默认最小权限**：页面、插件、SSH Agent、移动系统填充只取得完成当前操作所需的秘密。
3. **安全与可用性同等可验证**：保存成功、远端同步成功、备份有效是不同的状态。
4. **不静默丢失数据**：同一敏感字段发生冲突，必须保留所有候选版本直到用户决策。
5. **协议先于实现**：SQLCipher Schema、UI 和云供应商 API 不应反向定义开放 Vault 格式。
6. **拒绝自制密码学原语**：采用成熟的标准算法和库，只定义必要的文件封装与版本协议。

02. 已确认的关键决策

主题	V1 确定方案	说明
产品名称	CredPivot	暂定，商标和域名需另外核查
核心语言	Rust	核心数据、加密、同步、MFA、SSH 共享实现
UI 技术	Flutter	macOS、Windows、Android、iOS；原生桥接保留
浏览器扩展	TypeScript / WebExtensions	必须依赖已安装的 CredPivot App
本地数据库	SQLCipher	本地查询、事务、索引、历史密码与同步队列
用户 Vault 位置	首次启动可选目录	未选择则使用系统默认应用数据目录
主密码与恢复	主密码 + 256-bit 随机恢复密钥	各自包装 Vault 主密钥，非短数字恢复码
快捷解锁	系统指纹 / Face ID / Windows Hello 等	设备级密钥包装，不能替代通用解锁凭据
云端格式	OVB1 Snapshot + Delta	与 SQLCipher 文件格式解耦
首发双向同步	WebDAV	本地离线队列 + 冲突合并
后续同步	S3、Google Drive、OneDrive 等	通过 Provider Adapter 扩展
Git	初始化 / 单向 Push / 恢复	不是同步 Provider，不参与冲突解决
数据模型参考	FIDO CXF 1.0	参考 Item / Credential 模型，不直接替代 OVB
标准兼容	TOTP、OpenSSH、CXF、KDBX	分阶段实现导入导出，明确损失字段提示

决策状态说明：上述条目为用户已确认的方向；具体密码学参数、SQLCipher 二进制发布策略、移动沙盒目录范围及不同云服务一致性语义仍需工程验证。未经安全审计，不将本文示意编码视为生产加密规范。

03. 产品范围、用户画像与优先级

3.1 目标用户

- **普通用户**：管理网站账号、生成随机密码、指纹解锁、自动填充及 TOTP。
- **开发者**：同时管理 Git 托管平台账号、SSH 密钥、服务器身份、API Token、安全笔记。
- **多设备用户**：在电脑和手机间通过 WebDAV 同步，能够离线编辑并在联网后无损合并。
- **数据控制型用户**：自选 Vault 路径、自托管 WebDAV、使用加密备份、脱离原产品恢复。

3.2 首发 P0 能力

域	P0 范围
Vault	初始化、主密码、恢复密钥、锁定、生物识别、目录管理、完整性检查
密码	新增/编辑/删除、生成、搜索、域名匹配、历史 N 条、修改日期提醒
MFA	TOTP 导入/生成、二维码识别、账号关联、备份恢复码存储
SSH	Ed25519 创建、OpenSSH 导入/导出、主机映射、桌面 Agent 与授权
同步	WebDAV 初始化、离线 Outbox、Snapshot/Delta、跨设备合并与冲突提示
备份	加密归档、Git 单向 Push、独立恢复 CLI
客户端	macOS、Windows、Android、iOS 的核心应用与系统集成
浏览器	Chrome、Firefox、Edge、Safari 桌面适配；扩展依赖本地 App
体验	深浅色、全局搜索、键盘操作、状态反馈、首次引导、无障碍基础

3.3 P1 / P2 延后范围

P1：Passkey 全生命周期、HOTP、KDBX 完整双向互导、S3、Google Drive、OneDrive 适配、更多开发者凭据模板、附件分块上传、密钥使用审计视图。P2：团队共享、设备间安全配对、紧急访问、跨多后端同时可写、多用户权限模型。所有延后项需在 V1 数据模型中保留扩展能力，但不得让未实现功能阻塞首发核心安全能力。

04. 统一账号与凭据数据模型（参考 CXF）

4.1 设计依据

参考 FIDO Alliance Credential Exchange Format（CXF）1.0 的 Item / Credential 可组合思路：一个 Item 可以携带多种凭据。CredPivot 内部定义自己的稳定实体 ID、关系与同步修订信息，并提供映射层实现 CXF 导入导出。CXF 是交换格式参考，不是 SQLCipher Schema，也不是 OVB 加密容器。[R01]

4.2 逻辑实体

实体	职责	关键字段（逻辑层）
Vault	单个独立保险库	vault_id、格式版本、策略
Item / Account	某网站/服务/项目的凭据聚合	id、名称、URL、标签、分组、图标

实体	职责	关键字段（逻辑层）
Credential	可组合的登录/认证对象	id、item_id、type、data、revision
LoginSecret	账号密码	用户名、密码、生成/启用时间、匹配规则
TotpSecret	时间型 OTP	Base32 种子、issuer、算法、period、digits
SshIdentity	SSH 身份材料	算法、公钥、私钥、注释、指纹、使用规则
SshHost	连接目标	主机、端口、用户、Host Key 指纹、密钥关联
RecoveryCodeItem	网站备用恢复码	服务、密文码列表、已使用标志
PasswordHistory	历史密码	归属、密文、产生/启用/退役时间
SecretNote / Token	其他敏感信息	类型、字段、可见/隐藏策略
Revision / Conflict	同步演进	revision_id、parent、device、冲突状态

实体之间允许一对多和多对多链接。例如一把 SSH Key 可用于多台主机，一个账号可关联多个登录身份与 TOTP；所有外键关系在解锁后的数据库中维护，不将业务 ID、网址或用户名暴露到远程明文文件名。

4.3 时间字段语义

- created_at：记录在 CredPivot 中首次创建时间；导入后仍为导入时间。
- password_generated_at：当前随机密码被生成的时间（可能还未在网站启用）。
- password_activated_at：用户确认已在网站实际启用的时间；提醒以此为主要基准。
- password_changed_at：CredPivot 内密码内容最近被修改的时间；可与启用时间不同。
- last_verified_at：用户最近确认有效的时间；不能自动替代实际启用时间。
- retired_at：旧密码退役时间。

未知的实际启用时间必须保留为未知，不可把导入日偷偷当作启用日。所有时间使用带 UTC 语义的时间戳存储，UI 根据用户时区显示。

4.4 不允许被无意丢弃的扩展字段

任何 CXF 不包含或其他软件不支持的字段（如同步修订、历史 N 条、SSH 授权策略），必须通过显式转换器处理。导出前显示兼容性报告：可保留、降级、自定义扩展、无法导出。不能声称“CXF 兼容”就能保证所有字段无损往返。

05. 密码管理器功能规格

5.1 凭据创建与使用

支持手动新增、浏览器提示保存、导入、密码生成器；字段包括标题、服务 URL、用户名、密码、标签、说明、自定义字段、关联 MFA / SSH 身份。浏览器从注册或密码修改表单捕获后必须请求用户确认，不可在未知页面后台默默写入。

密码生成器应支持随机字符、长度、字符集、排除歧义字符与词组密码。使用操作系统安全随机源。默认推荐高熵随机生成，而不是依靠复杂但容易预测的用户模式。支持一键复制并设置剪贴板清理策略，但不保证第三方剪贴板历史功能已经被清除。

5.2 密码生命周期与提醒

确认规则：默认启用 90 天检查提醒，用户可以全局或按单条凭据覆盖；提醒不代表强制过期。 用户可选 30/60/90/180/365 天及关闭。判断时优先使用 password_activated_at；未知时显示“启用时间未知”，邀请用户确认，而非重置时钟。

到期提醒的含义是“检查是否需要修改密码”。若证实账号已泄露或密码被重用，系统可以提供高优先级建议；不能擅自自动更改远端网站密码。NIST SP 800-63B 不支持无泄露依据的强制周期性密码更换，本产品仅提供可选提醒工具。[R06]

5.3 密码历史

- **默认保留最近 10 个旧密码，不计当前密码**；全局可设置保留 0 至 50 条，单条可覆盖。
- 旧密码包含原值、生成时间、启用时间、退役时间以及修改原因（可选）。
- 修改密码时，在同一 SQLCipher 事务内将旧值写入历史、新值写入当前记录，并记录同步 Outbox。
- 无法判断网站是否已经更新时，新密码标记为“尚未确认启用”，历史切换需用户确认。
- 恢复历史值应创建新的修订版本和新的启用记录，而不是覆盖或抹去审计线索。
- 历史条数上限仅限制当前逻辑 Vault 可见内容；旧 WebDAV 快照、Git 提交和离线设备可能仍拥有旧密文副本。

5.4 搜索与安全中心

搜索支持服务名、域名、用户名、标签、收藏、类别；搜索索引只驻留已解锁 SQLCipher 或内存，不生成持久化明文索引。安全中心展示弱密码、重复密码、未知启用时间、到期提醒、缺少 MFA、久未使用等；所有可本地完成的检测默认离线执行。

5.5 删除与回收

删除先进入加密回收站，保留删除 Tombstone 以参与同步。用户可恢复或永久删除逻辑记录；界面需说明外部历史快照和旧设备可能仍保留此前密文。对高风险秘密建议轮换真实网站凭据，而非仅删除 Vault 项。

06. MFA 管理功能规格

6.1 TOTP

P0 实现 RFC 6238 TOTP，支持常见 6/8 位、30 秒默认周期以及 SHA-1 / SHA-256 / SHA-512（按凭据参数）。支持扫描二维码、读取 otpauth:// URI、手动输入 Base32 种子、备份和恢复。显示剩余有效时间，临近过期时应避免复制即将失效的码。[R07]

MFA 可在账号详情作为关联 Credential 显示，浏览器填充时根据已确认的网站 Origin 和用户选择推荐对应验证码。不能仅因为页面出现六位输入框就自动提交 TOTP。

6.2 备用恢复码

网站提供的恢复码属于该网站的凭据数据，与 CredPivot 自身的 Vault 恢复密钥分开存储和命名。支持录入多条、复制单条、手动标记已用和剩余数量。用户若同时把密码与 TOTP 种子放在同一 Vault，应说明其便利性与“单点泄露可暴露多个认证因素”的风险。

6.3 HOTP 与 Passkey

HOTP 因设备间计数器冲突涉及特殊同步语义，计划放到 P1；Passkey 的平台凭据提供与迁移涉及 WebAuthn / FIDO 交互和更复杂的权限限制，P1 单独设计。V1 模型应允许新增 Credential 类型，但不提前承诺未实现的系统 API 能力。

07. SSH 管理功能规格

7.1 密钥与主机管理

默认推荐生成 Ed25519；允许导入用户现有的 OpenSSH 私钥，兼容常见 RSA / ECDSA，并采用兼容性、安全策略与算法禁用清单。展示公钥、指纹、注释、用途、创建日期、使用范围、关联账号/主机。私钥默认保留在 Vault 内，不应为了日常 SSH 操作而自动导出为磁盘明文文件。

主机模型包括 hostname、port、username、host_key_fingerprint、备注、JumpHost（P1）和多个身份候选。主机公钥指纹变更必须提示确认，不能悄悄信任新指纹。

7.2 桌面 SSH Agent

macOS 和 Windows 提供 SSH Agent 兼容接口，由独立 Vault Agent 持有短期解锁上下文并执行签名请求。策略分为“已授权会话允许”“每次签名确认”“高安全每次生物识别确认”。支持按密钥、调用来源、会话定义授权限制。

SSH Agent 通常不能从通用签名请求中可靠证明最终 SSH 主机身份，因此不能把“自动识别所有最终目标主机”视作安全前提。无法可靠绑定目标的请求，应采用用户可理解的保守授权规则。

7.3 SSH 与 Git 的联动

同一 GitHub Item 可以关联网页登录密码/TOTP 和 Git over SSH 的 Ed25519 密钥。在终端执行 git push 时，Vault Agent 根据用户配置提供密钥签名，浏览器则使用同一 Item 的网页登录凭据。Git 单向备份自身的首次认证要支持独立外部 Git Token/系统 SSH 密钥，避免“必须先解密 Vault 才能取得克隆 Vault 的 SSH 密钥”的循环依赖。

7.4 移动端边界

iOS/Android 提供密钥查看、生成、导入/导出及受支持客户端的交互能力；不承诺像桌面系统一样向所有第三方 SSH 客户端暴露全局 Agent。涉及私钥导出和复制的操作均需二次确认与本地授权。

08. 三模块联动与核心用户旅程

8.1 关联演示：GitHub 工作账号

```
Item: GitHub / Work
  Login Credential  -> github.com (username + password)
  TOTP Credential   -> issuer=GitHub (TOTP seed)
  Recovery Codes    -> GitHub backup codes
  SSH Identity      -> Ed25519 key for git@github.com
  Ssh Hosts         -> github.com; associated work machines
```

8.2 首次创建 Vault

1. 用户选择“创建新 Vault”或“导入已有 Vault”；创建时展示本机默认目录及自定义目录选择。
2. 用户输入并确认主密码，显示强度提示与离线猜测风险，不将主密码发往服务器。
3. 核心生成 256-bit Vault 主密钥（VMK）及 256-bit 恢复密钥，分别创建 Key Slot。
4. 用户查看、打印或抄写恢复密钥，并完成一次局部校验；应用不允许略过恢复风险说明。
5. 初始化 SQLCipher、协议版本、设备身份、本地加密存储及空 Outbox。
6. 用户可选择绑定系统生物识别，并配置 WebDAV；未配置时仍能完全离线使用。

8.3 浏览器保存和同步密码

1. 扩展检测注册/修改密码操作并确认当前网页 Origin。
2. 用户确认保存后，扩展向本机 Native Host 提交最小必要字段。
3. Host 验证扩展身份与会话权限，Agent 转交 Vault Core。
4. SQLCipher 事务同时更新 Credential、History/Revision 和 Sync Outbox。
5. 扩展展示“已在本机加密保存”；远端状态另行显示“待同步/已同步/冲突”。
6. WebDAV 后台上传加密 Delta；另一设备拉取、校验、合并并更新本地数据库。

8.4 多设备编辑同一密码

A、B 离线时分别修改同一密码，回网后不能用“最新时间戳”覆盖另一端。两份修订保留为同字段冲突；用户在冲突对比界面选择最终当前密码，另一份进入历史或冲突归档，并发布解决操作。所有版本与冲突处理记录均存在加密存储中。

8.5 找回主密码

用户取得完整 OVB 归档或同步数据 + 恢复密钥，经独立恢复工具解开 VMK，设置新主密码包装槽，并根据需要重建本地 SQLCipher；恢复工具不得依赖 CredPivot GUI、厂商在线账户或设备生物识别。若主密码和恢复密钥同时丢失，不能提供后门式恢复。

09. 跨平台交付与浏览器扩展

9.1 交付矩阵

平台	客户端形态	系统集成与限制
macOS	Flutter 桌面 App + 原生桥接	Touch ID、Keychain、SSH Agent、浏览器 Native Host
Windows	Flutter 桌面 App + 原生桥接	Windows Hello、系统保护密钥、SSH Agent、Native Host
iOS	Flutter App + Apple Extension	Face ID/Touch ID、AutoFill Credential Provider、Safari 集成
Android	Flutter App + Android Service	BiometricPrompt、Keystore、AutofillService / Credential Provider
Chrome / Edge	TypeScript 扩展	Native Messaging，仅桌面本地 App 配套运行
Firefox	WebExtensions 适配	Native Messaging，权限与 Host 注册独立适配
Safari macOS	Safari Web Extension + 宿主 App	与已安装 CredPivot App 配套，不独立持库
移动浏览器	以系统填充为主	不假定可安装等同桌面版的 Chrome/Firefox 扩展

Android 的 Credential Provider 与 Apple 的 AutoFill 框架需使用各自的系统 APIs，不能把桌面 Native Messaging 设计直接复制到移动端。[R11][R12]

9.2 浏览器扩展必须依赖应用

强制规则：未安装 CredPivot 的浏览器扩展只能展示连接/安装引导；已安装但 Agent 不可达时不能独立解密、浏览、修改或同步 Vault。扩展不建立 SQLCipher/IndexedDB 独立保险库，不持久化 VMK、主密码或登录秘密。主应用窗口可以关闭，但配套 Agent 必须能够在授权条件下按需运行。

浏览器内容脚本只用于定位字段和必要交互；Native Messaging 请求由扩展受信任后台发起，并通过 Host 身份白名单、配对、消息类型白名单、Origin 核验与用户授权实施最小权限。[R10]

9.3 扩展核心页面与行为

扩展弹窗包含当前站点推荐账号、搜索、复制 TOTP、密码生成、保存/更新、锁定状态、连接状态及“打开 CredPivot”。网页默认不无条件自动填充；用户可选择“此站点自动建议/点击填充”，对 HTTP、相似域、跨域 iframe、未知 Origin 进行保守处理。

浏览器插件状态必须可识别：“未连接 App”“Vault 已锁定”“已连接”“保存中”“本地已保存”“待同步”“保存失败”。Native Host 不可用时不能伪造保存成功。

9.4 系统填充隐私边界

iOS/Android 系统自动填充可能要求向操作系统提供必要的身份/域名索引。CredPivot 要明确告知此类索引不等同于 SQLCipher 主 Vault；提供“标准填充模式”与可选“增强隐私模式”，后者尽量减少对系统身份索引的发布，但可能牺牲快捷推荐体验。不得宣称系统全局不存在任何元数据。

10. 现代化 UI 与交互设计规范

10.1 产品体验定位

视觉取向为**专业、安静、轻量、可信赖**，避免传统密码管理器过度密集的表单式界面，也不把安全警告全部做成刺眼的红色。统一的低噪声界面让用户在几秒内找到服务、识别凭据类别、完成当前任务。

设计系统命名为 CredPivot Design System / CPDS，共享颜色、字重、间距、圆角、动效与状态 Token，桌面和移动端使用同一信息架构但不同的导航方式。

10.2 全局信息架构

桌面主导航：总览、全部凭据、密码、MFA、SSH、收藏、安全中心、同步与备份、设置。默认左侧导航 + 中间凭据列表 + 右侧详情检查器，窗口较窄时折叠为双栏或单栏；全局搜索和“新增”是始终可见的首要操作。

移动主导航：保险库、验证器、SSH、设置，顶部搜索与新增；账号详情采用分区卡片展示关联 Login/TOTP/SSH，不强迫用户跳转三次。适配单手使用和系统大字体。

10.3 视觉基础 Token（初稿，可经 UI 验证微调）

Token	默认建议	说明
Base spacing	4 px 基础网格；常用 8/12/16/24	减少临时布局值
组件圆角	10–14 px	卡片现代但不过度胶囊化
界面字体	系统优先 + Noto Sans CJK 兼容	中文/英文/密码字符清晰
正文字号	桌面 14–16 px；移动遵循系统缩放	不因信息密度牺牲可读性
颜色主题	浅色 / 深色 / 跟随系统	高对比模式另行适配
强调色	冷蓝青 / 灰蓝中性色（设计阶段定稿）	红色仅用于有意义的危险状态
动效	120–240 ms 的适度过渡	尊重减少动态效果设置
图标	统一线性矢量图标	密码/MFA/SSH 图标语义稳定

10.4 核心页面详细交互

首次引导（向导式）：欢迎与导入 → 选择 Vault 目录 → 创建主密码 → 保存恢复密钥并验证 → 绑定生物识别 → 配置同步（可跳过） → 连接浏览器。单步有清楚的主操作、帮助、错误恢复，不以营销说明干扰安全操作。

保险库列表：支持卡片/紧凑列表切换，图标 + 标题 + 用户名 + 凭据类型标记。悬停/轻扫显示复制用户名、复制密码、查看 OTP、打开网站；复制秘密前考虑锁定与重新验证策略。搜索结果可显示关联账号集合，避免同站点多账号混淆。

详情抽屉：首屏展示登录身份、域名和核心操作；密码默认遮挡，点击眼睛暂时查看；下方按“登录 / MFA / SSH / 历史 / 备注”分段。编辑采用显式保存与取消，离开未保存的敏感修改时明确提示。

安全中心：不要只展示抽象分数。优先展示“重复密码 8 项”“已到期检查 12 项”“无 MFA 的重要账户 4 项”“同步冲突 1 项”等可执行事项，并提供一步到达对应账号。

同步与备份：使用时间轴或清晰状态块分别展示“本地已保存”“同步中”“最后同步时间”“有未解决冲突”“上次备份验证”。显示 Provider 名称但不泄露敏感 Token；同步失败提供可理解错误与重试操作。

SSH 操作授权：弹出原生风格的明确确认卡，显示使用的是哪把密钥、操作类别、调用来源及该次/该会话授权范围；不可将未知来源请求包装成“已验证目标服务器”。

10.5 交互标准与无障碍

- 快捷键：全局搜索、快速锁定、复制当前凭据、创建记录；可在设置中查看并自定义部分组合。
- 所有异步保存/同步动作必须有明确完成、失败、可重试状态；禁止静默吞错。
- 所有危险动作（删除最后一份备份、导出明文、替换 SSH 私钥、密钥轮换）均使用可理解的分级确认。
- 支持键盘全操作、屏幕阅读器语义、可聚焦控件、色彩对比度与系统大字号；以 WCAG 2.2 AA 为设计检查基线。[R15]
- 支持减少动效和系统主题；不会只用颜色区别同步成功、失败和冲突。

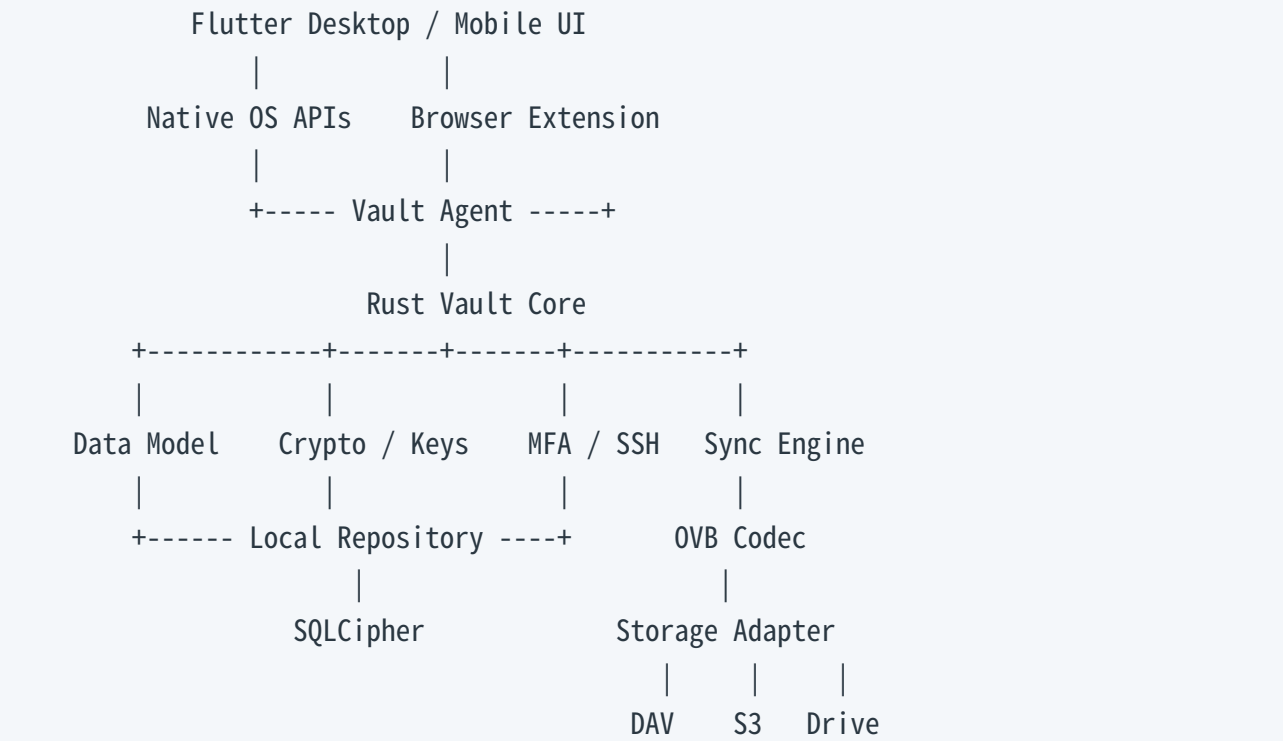
- 空状态提供下一步动作，弱网络状态可离线继续；指纹失败应解释主密码回退路径。

10.6 UX 验收用例

从打开桌面应用到搜索并复制一个已解锁密码，目标 3 个以内的明确操作；新增账号时能够直接关联 TOTP；用户可在详情页看到密码何时生成、实际启用、何时检查和保存的历史个数；浏览器新增后本机列表立即可见，并能区分本地保存和云端同步状态。以上是操作设计目标，发布前以可用性测试验证。

11. 系统分层架构与工程选型

11.1 总体逻辑分层



核心约束：所有持久化凭据业务写入经过 Rust Vault Core 的统一接口，数据库写入与 Outbox 同一事务。界面、Agent、浏览器扩展和 SSH 子系统不得绕过授权边界直接访问 SQLCipher 文件。

11.2 建议技术栈

层	实现	说明
核心库	Rust stable	加密、序列化、数据模型、合并、同步、OTP、SSH
密码学原语	成熟、经过审计的 Rust/系统库	Argon2id、HKDF、AES-GCM、随机数、Ed25519
本地数据库	SQLCipher + Rust FFI/绑定	固定版本与构建参数；发布包静态或随包部署

层	实现	说明
桌面/移动 UI	Flutter / Dart	统一 Design System 与大部分业务界面
原生适配	Swift、Kotlin、Windows API	Keychain/Keystore/Windows Hello 与系统填充
浏览器扩展	TypeScript + WebExtensions	Chrome、Firefox、Edge、Safari 各自打包适配
本地代理	Rust Vault Agent	Native Messaging、密钥授权、操作系统 IPC
恢复 CLI	Rust	无 GUI、无供应商服务器的独立恢复与导出
协议	OVB1	标准化编码、加密容器、快照/Delta 语义

Go 可用于将来辅助的云部署工具、校验器或运维服务，但 V1 不引入 Go 常驻服务，也不因语言偏好在移动端与浏览器中复制密码学实现。

11.3 API 与进程边界

- VaultCore：统一公开 create/update/delete/list/get、unlock/lock、generate_password、OTP、Agent authorize、sync、backup、export 等受控接口。
- VaultAgent：桌面常驻或按需启动、管理单机实例与对外 IPC；不要求 Flutter 主窗口常开。
- Native Host：浏览器消息入口，负责消息大小限制、扩展 ID 校验、会话握手、转交 Agent。
- PlatformBridge：封装设备生物识别、系统安全存储、通知、系统自动填充与目录权限。
- Sync Provider：只实现远程对象操作，不访问业务明文、不接触 SQLCipher 查询语义。

单写入者规则：同一 Vault 在同一设备内通过 Agent / Core 串行提交业务写事务。可允许数据库内部多读连接，但统一协调 Outbox、锁状态、版本冲突与数据迁移。

11.4 工程目录建议

```
credpivot/
  crates/
    crypto/                # key slots, AEAD, KDF, zeroization
    model/                 # Item / Credential / Version / CXF mapping
    repository-sqlcipher/  # schema, migrations, transactions
    ovb-format/            # canonical codec / snapshots / deltas
    sync-engine/           # merge, outbox, reconciliation
    provider-webdav/       # first sync adapter
    provider-api/          # capabilities, storage traits
    otp/                   # TOTP and import
    ssh/                   # keys, policy, agent protocol
```

```
  platform-ffi/          # Dart and OS bindings
apps/
  flutter/               # desktop / mobile UI
  browser-extension/     # browser packages
agents/
  vault-agent/
  native-host/
tools/
  credpivot-cli/
specs/
  ovb-v1.md
  crypto-v1.md
  sync-v1.md
  cxf-mapping-v1.md
  test-vectors/
tests/
  crypto/ sync/ recovery/ platform/ security/
```

12. SQLCipher 本地持久化与 Vault 目录

12.1 使用 SQLCipher 的理由与限制

SQLCipher 作为正式本地数据库引擎，提供成熟的 SQL、索引、事务与数据库页面级透明加密，不需要开发团队自造关系查询引擎。它基于 SQLite 生态，本身不需要数据库服务进程。[R03]

其代价包括：需要打包 SQLCipher 与密码学 Provider、处理 Flutter/Rust FFI 和各平台编译链、升级兼容测试，以及运行时可能创建 WAL/SHM/临时文件。正式发行前必须测试所有平台的 Release 安装体积，不对尚未测量的二进制增量作数字承诺。

12.2 Vault 存储目录策略

首次启动向导提示用户选择目录；不选择即使用系统默认应用数据目录。桌面允许使用符合安全要求的自定义本地目录；需校验可写权限、剩余容量、符号链接/路径逃逸、文件系统原子替换与锁能力。默认禁止把正在使用的数据库直接放在 WebDAV 挂载目录、网络共享、第三方实时云盘同步目录或不保证 SQLite 文件语义的位置。可在设置中查看和迁移。

macOS/Windows：真实 SQLCipher 数据库可保存在用户授权的本地目录。**iOS/Android**：优先使用应用沙盒中的数据库目录；系统文件选择器选到的外部位置主要作为加密归档导出或备份位置。不能保证所有移动端 SAF/文件提供器路径都支持数据库随机读写、锁和 WAL。UI 应区分“工作 Vault 位置”和“导出/备份位置”。

12.3 建议目录结构

```
CredPivotVault/
  vault.json              # OVB1 version + wrapped VMK slots
  vault.db                # local SQLCipher database (encrypted)
  attachments/
    7a/opaque-blob.enc    # encrypted large blob (optional)
  runtime/                # implementation-owned auxiliary files
  backups/                # optional local encrypted packages
```

运行期间 SQLCipher 可能生成 vault.db-wal、vault.db-shm 等辅助文件。数据库 WAL 中包含加密页，SHM 为数据库同步元数据，临时文件仍需专项审计。不得用直接复制打开状态下的 .db 文件作为一致性备份。[R03][R04][R05]

12.4 数据库逻辑 Schema（V1）

表	存储内容	关键一致性要求
vault_meta	本地格式、数据库 Schema 版本	仅允许按迁移计划升级
items	服务/账号聚合项	稳定 ID、软删状态
credentials	类型化凭据、关联、内容	按 Item 关联与版本约束
password_history	最近 N 条旧密码	修改密码事务内裁剪
ssh_hosts	主机配置与身份映射	主机指纹变化需确认
record_revisions	当前与父修订、冲突图	不允许隐式覆盖
sync_outbox	待上传的业务 Delta	与业务写入同事务
sync_inbox	下载但尚待应用的 Delta	具备幂等去重
sync_devices	活动设备与同步水位	设备遗失有明确策略
sync_conflicts	多端冲突候选	未解决不可静默删除
attachments	元数据与密文 Blob 引用	提交与垃圾回收一致
settings	Vault 范围配置	敏感设置保留在密文中

对强约束字段创建索引，但索引也必须驻留 SQLCipher；公开元数据仅限启动解锁所必须的协议参数。数据库迁移采用整数 Schema 版本与“升级前一致性验证 → 升级 → 完整性检查 → 结果提交”流程，升级失败回退到原加密备份。

12.5 事务示例：修改密码

```
BEGIN IMMEDIATE
  1. 读取 Credential 当前修订
  2. 当前密码写入 PasswordHistory
  3. 更新当前密码、时间字段和 Revision
  4. 超过 N 条时裁剪逻辑历史
  5. 写入不可丢失的 sync_outbox 事件
COMMIT
```

必须先提交到本地数据库，再异步上传云端；不能把云端成功作为本地保存完成条件。崩溃重启后重放持久化 Outbox，幂等操作不可重复产生业务副作用。

12.6 数据库密钥来源

主密码不直接喂给 SQLCipher。主密码经 Argon2id 派生 KEK，解出随机 VMK；由 VMK 通过带域分离的 HKDF 派生数据库原始密钥，再交给 SQLCipher。由此可实现独立恢复密钥、生物识别快捷解锁与对数据库密钥的统一管理；须在实现中固定原始密钥配置及 SQLCipher 兼容参数。[R03]

12.7 存储位置迁移

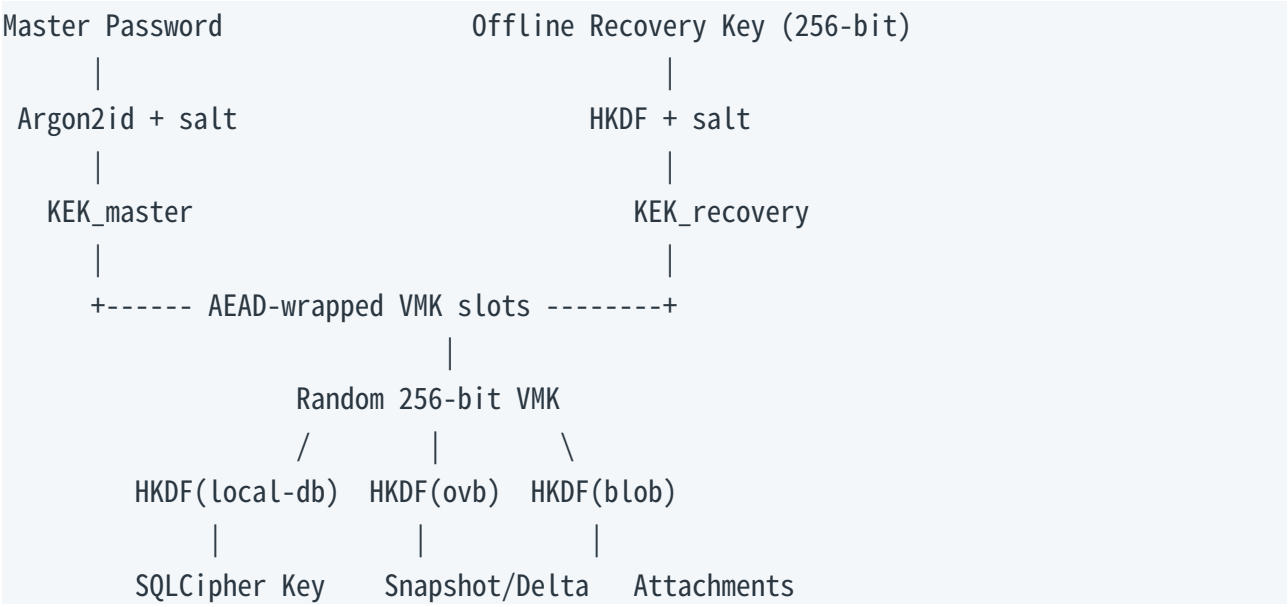
关闭写入入口 → 形成一致性数据库副本 → 将全部 Vault 组件复制到新位置 → 校验 SQLCipher 完整性与附件引用 → 原子更新本机路径指针 → 重启 Agent 与数据库连接。任何环节失败则保持原路径可用。旧目录的普通删除不能视为密码学安全擦除，特别是 SSD、快照和云盘历史场景。

13. 密钥体系、加密与恢复

13.1 不作绝对暴力破解承诺

离线保险库没有服务端限速。攻击者一旦获得完整密文，就可以在自己的设备上反复猜测主密码；KDF 只能提高猜测成本，无法对弱密码给出“绝对不可破解”的承诺。安全目标是采用高熵主密码、内存困难 KDF、足够随机盐、强认证加密、无后门，并针对暴力猜测进行成本测试。

13.2 密钥层级（拟定规范）



1. VMK 在 Vault 创建时由 CSPRNG 随机生成，长度为 256 bit。
2. 每个主密码 Key Slot 独立随机盐；Argon2id 参考 RFC 9106 的内存受限推荐配置（64 MiB、3 次迭代、4 lanes）作为设备实测起点，不对所有平台硬编码相同时延。[R02]
3. 恢复密钥由 CSPRNG 生成 256-bit 秘密，人类可读格式通过 Base32 分组与校验码展示，不使用短数字码作为唯一离线恢复凭证。
4. KEK 使用 AES-256-GCM 等标准认证加密算法包装 VMK，每个包装具有全新 nonce；AAD 绑定 Vault ID、Slot ID、类型、格式版本及参数编码。
5. 派生本地数据库、远程对象、附件及协议完整性密钥时，使用明确的 HKDF 域分离标签，避免同一个密钥跨用途复用。
6. 远程 Snapshot、Delta 与 Blob 使用独立的加密子密钥/nonce 方案；编码、AAD、头长度、输入大小上限须在 crypto-v1.md 字节级冻结并提供测试向量。
7. 使用成熟密码学库而非自制算法。所有密钥材料尽可能短时保留，锁定后清理可控内存并停止敏感 IPC。

13.3 生物识别快捷解锁

首次使用主密码解锁后，应用可在本机创建受系统保护的设备密钥，并以其包装 VMK 的设备本地副本。后续通过 Touch ID、Face ID、BiometricPrompt、Windows Hello 等系统机制授权解开本地包装；该包装不上传云端，也不能用于其他设备。更换设备、重装或密钥丢失时需主密码/恢复密钥重新建立设备授权。

设备指纹不是可供应用导出的对称密钥材料；生物识别只作为操作系统访问受保护密钥的授权条件。系统解锁策略、失败回退、设备重启后重认证和高级风险操作二次确认都须在平台层测试。

13.4 修改主密码与安全密钥轮换

普通修改主密码：仍使用原 VMK，仅重写主密码包装槽。快速、无需重新加密业务数据，但旧备份或 Git 旧提交可能保有旧包装槽；知道旧密码的攻击者若拥有旧历史，仍可能取得原 VMK。

安全重建 / 完整密钥轮换：生成新 VMK，重新加密现有逻辑对象、生成全新 Vault 历史与备份目标；为新主密码和恢复密钥重建包装槽；要求其他设备重新导入或重新配对。此操作不能抹掉已被复制到外部仓库或旧设备中的原明文凭据，必要时仍须在网站/服务器轮换实际密码、TOTP 或 SSH 私钥。

13.5 恢复密钥的正确语义

恢复密钥是独立高熵的第二个解锁入口，**不是可以从 Git 历史中彻底撤销的“一次性恢复码”**。应在产品中称为“保险库恢复密钥”。如用户认为该密钥已泄露，应执行完整密钥轮换与重新发布备份，而不是只删除当前 vault.json 的旧 Key Slot。

13.6 独立恢复要求

必须同时交付公开的 OVB/crypto 规范、兼容参数、Schema 映射、加解密测试向量和 credpivot-cli。CLI 支持 inspect、verify、recover、export-cxf 等操作；主密码通过交互式安全输入获取，不经命令行参数或 Shell 历史传递。第三方不依赖 CredPivot 专有服务器，也能依据规范实现恢复器。

14. OVB1 开放加密交换格式

14.1 格式定位

OVB1 是 CredPivot 拟制定的开放格式，不声称为现有行业标准。 它用于跨设备同步、服务迁移与独立恢复；SQLCipher 是本地工作数据库，不要求所有平台或第三方恢复工具直接读取 CredPivot 的实时数据库文件。CXF 提供业务交换模型参考，KDBX 作为成熟加密保险库兼容目标。[R01][R13]

14.2 远程逻辑目录

```
vault-ovb/
  vault.json                     # protocol + key slots; no secrets in clear
  snapshots/
    <opaque-snapshot-id>.ovbs    # authenticated encrypted full snapshot
  deltas/
    <opaque-device-id>/
      <seq>-<opaque-op-id>.ovbd  # immutable encrypted operation
  blobs/
    <opaque-blob-id>.ovbb        # encrypted attachment
  checkpoints/
    <opaque-checkpoint-id>.ovbc  # optional sealed watermark/metadata
```

目录名称、文件数量、大小、更新时间可能被存储提供商观察到；业务名称、站点、用户名、TOTP 种子、SSH 私钥和记录修订内容必须存在于密文中。外部对象 ID 使用不可推断业务语义的随机标识，不使用明文网站 URL 或用户名作为路径。

14.3 Snapshot 与 Delta

- **Snapshot**：某个因果水位（frontier）上的完整逻辑 Vault 状态；包含 Item/Credential、历史 N 条、关系、删除标记、设备信息、Schema 版本及对象引用。完整性使用 AEAD，并在密文内部附校验域及上游变更覆盖范围。
- **Delta**：一个或一组原子业务修改，包含操作 ID、设备 ID、单调递增设备序号、父修订、数据修改、删除 Tombstone、关联变更。用于幂等重放和冲突判定。
- **Blob**：大附件独立加密，按不含业务语义的 ID 引用；V1 应明确附件大小上限和拒绝超限策略。
- **Checkpoint**：可选的已认证快照发现/对账信息，不能在缺乏兼容性校验时作为强制全局锁或唯一可信真相源。

快照是优化首次恢复和压缩重放成本的缓存检查点，**不能因为出现新快照就立即删除旧 Delta**；否则长期离线设备可能失去识别分叉和恢复的必要证据。

14.4 二进制与版本化规则

V1 建议采用确定性编码（例如规范化 CBOR 或经严格冻结的 Canonical JSON）来编码加密前的协议结构；格式设计审查后选定一种，不允许由 SDK 默认序列化行为隐式决定字节顺序。所有整数宽度、时间单位、UTF-8 规范、Base64url、nonce、AAD 和最大字段长度必须有可公开测试向量。

每个加密对象头需要 magic、format_version、object_kind、opaque_id、algorithm_id、nonce、ciphertext_length，正文由密文及认证标签构成。未知算法、未知主版本、过大的参数或认证失败均必须拒绝，不得静默降级解密。

14.5 协议兼容与数据迁移

- format_major 不兼容时拒绝直接修改，提供明确的只读/升级流程。
- format_minor 新增可忽略扩展字段时保留前向兼容；不允许未知关键安全字段被跳过。
- 任何协议升级都需确保老客户端不会写回破坏新字段的数据。
- WebDAV → S3/Drive 迁移应通过同一 OVB 对象规范实现，不依赖 SQLCipher 数据文件拷贝。
- 单文件 .ovb 归档包含协议描述、Key Slots、Snapshot、必要 Delta 与 Blob 的密文集合，并带清单完整性检查；归档打包本身不是明文导出。

14.6 安全的独立恢复最低输入

恢复器至少需要完整的 vault.json、一个可验证 Snapshot、Snapshot 未覆盖的必要 Delta、所有被引用的加密附件，以及主密码或恢复密钥。归档缺文件、哈希链不连贯、AEAD 校验失败时应显示部分损坏范围并默认中止自动恢复，而非输出表面成功的残缺保险库。

15. 快照 + 增量同步协议

15.1 同步目标

同一 Vault 可以在多台设备离线修改；联网后尽可能自动合并互不冲突的记录，涉及密码和其他敏感字段的同字段冲突需保留所有候选值。远程服务端只负责对象存储，不参与解密与业务合并。同步与备份分别显示状态。

15.2 本地状态机

```
Local transaction committed
          |
     OUTBOX_READY
          |
 Encrypt Delta once (persist envelope)
          |
     UPLOAD_PENDING
          |
    REMOTE_UPLOADED
          |
   REMOTE_DISCOVERY / DOWNLOAD
          |
  VERIFY -> MERGE -> APPLY INBOX
          |
      IN_SYNC  /  CONFLICT
```

上传超时后使用已持久化的同一不可变对象标识及密文重复提交，不重新生成内容不同但 nonce 相同的加密信封。只有对象确实被远端接受并通过必要的存在性检查才标记上传成功。

15.3 多设备变更发现

每个设备有随机不透明 Device ID 与独立递增序号；Delta 以不可变对象方式上传，并以“设备链前驱摘要 + 父修订 ID”建立可验证的因果关系。下载端列举远端已发现的对象，检查同一设备序号是否存在缺口；缺口时延迟合并或展示远端不完整状态，不以“尚未列到”推断该操作不存在。

V1 WebDAV 适配器需要通过真实服务测试可靠的目录列举、条件创建/防覆盖、分页/超时和错误恢复。未来若某 Provider 无法提供足够的对象发现与安全发布语义，应降级为备份用途或拒绝启用多写设备同步，不能凭统一接口名称假设所有云盘都满足安全同步前提。

15.4 合并规则

冲突类型	处理结果
不同 Item 各自修改	自动合并

冲突类型	处理结果
同一 Item 不同 Credential 修改	自动合并（关系校验通过时）
同一 Credential 不同独立字段修改	有共同祖先且无依赖冲突时字段级合并
同一密码两端修改	保留两个候选，用户决策，不按时间戳覆盖
一端删除、一端修改	标记删除/更新冲突，二者都保留
SSH 私钥两端替换	必须人工决策并校验对应公钥/主机关系
TOTP 种子两端替换	视为敏感冲突，不自动选择较新的值
重复收到同一个 Delta	使用 Operation ID 幂等跳过

冲突 UI 清楚展示设备来源、修改时间和字段类别；秘密值默认隐藏。解决冲突时生成新的合并 Revision，所有处理结果重新进入 Outbox。

15.5 快照生成与增量重放

新增设备获取 vault.json，用主密码/恢复密钥解锁，选择可验证的新快照，按快照水位重放后续 Delta。快照生成必须使用事务一致的业务状态视图，记录覆盖的设备水位与必要的前驱校验。出现 Snapshot 与 Delta 不一致时拒绝不可信合并并允许回滚到其他已验证快照。

V1 策略：周期性生成快照，但**暂不自动远端删除所有旧增量文件**。待后续设计设备确认水位、失联设备策略和备份保留期之后，再安全开启垃圾回收。这样牺牲部分存储空间，换取更清晰的首发安全边界。

15.6 删除、设备离线与设备撤销

删除操作通过 Tombstone 同步；长时间离线设备重新加入时仍必须能识别已删记录，避免无意“复活”。设备撤销应清除其未来自动参与权限，然而只要失联设备仍掌握旧 VMK，就无法纯靠服务端标签阻止其解密早已获取的密文；若设备丢失并可能泄露密钥，需要完整 VMK 轮换与真实凭据轮换评估。

15.7 防回滚边界

客户端本地保存可信的已见版本水位和设备链摘要，可以识别远端回退到已见更旧状态。但如果攻击者控制首次初始化时提供的所有数据，且用户没有任何可信独立锚点，纯离线协议无法普遍判断“这就是最新历史”。可引入安全的设备间指纹比较或备份检查点核验作为加强措施，不能宣传无条件防所有回滚。

16. WebDAV 与可扩展存储适配器

16.1 Storage Adapter 的职责边界

Provider 只实现对象层能力，不理解“密码”或“SSH”：列举、读取、不可变上传、条件发布、删除（明确开启时）、元数据/ETag 查询与错误分类。主密码、恢复密钥、VMK 和任何明文 Credential 不能传入 Provider。配置 WebDAV 凭据属于设备本地秘密，必须使用系统安全存储或 Vault 受控密文，并避免初次同步循环依赖。

最小接口草案：

```
trait ObjectStore {
    async fn list(&self, prefix: &str, cursor: Option<&str>) -> Result<Page>;
    async fn get(&self, key: &str) -> Result<Bytes>;
    async fn put_immutable(&self, key: &str, body: Bytes)
        -> Result<PutResult>;
    async fn stat(&self, key: &str) -> Result<ObjectInfo>;
    fn capabilities(&self) -> StoreCapabilities;
}
```

StoreCapabilities 至少描述：是否支持条件创建、条件覆盖、稳定列举、分页、对象大小上限、版本历史与目录创建。具有弱一致性或无法阻止覆盖风险的 Provider 需要进行兼容性测试；不能默认其支持多设备安全写同步。

16.2 首发 WebDAV Adapter

- 使用 HTTPS；证书验证默认严格，禁止“一键忽略所有 TLS 错误”。
- 首次配置以只存储随机测试文件的方式检查 PROPFIND、GET、PUT、目录创建、条件请求、ETag/Last-Modified 行为。
- 使用唯一、不可变对象 Key；适配器应优先提供条件创建与存在性校验，避免误覆盖。
- 若需要更新小型指针/Manifest，优先使用 If-Match / ETag 防止丢失更新；Manifest 不是唯一真相，无法可靠支持时不能拿它作为“同步成功”的唯一判断。[R08]
- 上传先本地持久化密文对象，失败重试；完成后核验可见性，再推进本地游标。
- 对 401/403、404、409/412、429、5xx、网络超时分别提供有意义的恢复提示；重试应具备退避和取消能力。
- 明确单个 WebDAV 根路径只保存一个 Vault ID；导入已有远端时验证 ID/格式并请求确认，避免错误覆盖另一 Vault。

16.3 后续支持其他云存储的原则

Provider	适配重点	对架构的要求
S3 / S3-compatible	Bucket、对象 Key、临时凭证、条件写入、费用/请求量	不依赖目录语义；上传保持不可变
Google Drive	OAuth、文件 ID、分页、应用可见目录选择	不把文件路径当唯一标识，需维护 Provider 映射
OneDrive	Microsoft Graph、OAuth、冲突行为、文件版本	明确条件更新与错误码映射
Dropbox	App 权限、变更列举、分页、速率限制	验证 Provider 特定一致性
本地/移动外部存储	原子文件写入与沙盒权限	工作 SQLCipher 文件和导出快照严格区分

S3 可使用条件写保护对象更新，但其具体语义与 WebDAV 并不完全等同。[R09] Google Drive 的 appDataFolder 隐藏目录适用于应用私有数据，却可能降低用户直接查看和独立迁移能力；优先提供用户可见目录和完整密文归档导出路径。[R14]

16.4 单主同步源和迁移

V1 每个 Vault 仅配置**一个可写同步 Provider**；可以配置多个只读或单向备份目的地。更换 Provider 使用受控迁移向导：暂停写入发布 → 校验本地 Vault 完整性 → 导出可验证 OVB Snapshot/Delta → 上传新远程 → 从新远程进行一次独立恢复校验 → 切换 Provider 配置。失败时保持原 Provider 可用，不自行删除旧远端数据。

17. Git 单向备份与灾难恢复

17.1 Git 的最终定位

Git 是 Backup Provider，不是双向 Sync Provider。只提供：（1）初始化一个备份仓库；（2）单一指定备份写入端对加密归档执行 Commit + Push；（3）恢复新设备时下载历史备份或指定提交中的密文文件。**不提供日常 Pull 同步、不做业务 Merge、不依赖 Git 历史作为密码历史数据库。**

17.2 备份写入规则

- Git 仓库内容是完整的加密 OVB 归档/对象，不包含用户明文秘密、主密码或本地设备生物识别包装材料。
- 默认只配置一台备份写入设备，减少仓库非快进冲突；Push 失败明确提示，不自动 force push。
- 定期备份应提供保留空间估计和 Git 仓库大小提示；加密数据库/快照变化可能导致 Git 对象增长。
- Git 凭据认证应可使用系统认证或独立 Git Token/SSH Key。首次克隆/恢复所需的认证材料不能完全被困在待恢复的 Vault 内。
- Git 备份与 WebDAV 同步互不改变彼此状态；Git 备份成功不能被 UI 误标记为 WebDAV 已同步。

17.3 历史秘密无法被逻辑删除撤销

删除密码、裁剪最近 N 条历史、修改主密码包装槽，并不会删除已上传 Git 历史中的旧密文和旧包装槽。拥有旧主密码与旧历史备份的人可能恢复旧 VMK。执行安全重建时应推荐使用新的仓库/备份位置，并提示旧仓库副本与克隆不一定能被彻底清除；高风险凭据在真实服务上需要轮换。[R16]

17.4 备份任务与演练

- 支持手动执行、退出/定期触发的计划式备份（按系统实际允许的后台能力）。
- 每次生成完整性摘要、备份 ID、创建时间及包含范围，保存本地审计状态。
- 定期演练使用隔离目录读取加密归档、验证对象关系、模拟主密码/恢复密钥解锁；成功后才显示“备份已验证可恢复”。
- 未经明确二次确认不得将明文导出结果写入 Git 仓库或共享目录。

18. 安全威胁模型与隐私设计

18.1 信任边界

需要分别防护：本地磁盘被复制、云服务提供商读取/篡改/回滚、浏览器恶意网页与内容脚本、本机其他进程滥用 Agent、设备丢失、导入恶意归档、历史快照泄露和同步时网络攻击。

不宣称完全解决：操作系统内核已被攻击者控制、攻击者长期监控解锁设备、用户输入低熵主密码、攻击者已读取运行中的明文内存等场景。产品必须公开威胁模型边界，而非使用“绝对安全”用语。

18.2 威胁与措施

威胁	主要防护	剩余风险 / 用户提示
Vault 数据目录泄露	SQLCipher + 密钥包装 + 高成本 KDF	弱主密码仍有离线猜测风险
远程云盘管理员窥探	OVB 认证加密、隐藏业务字段	对象大小、数量、时间可能泄露
远程篡改/替换	AEAD、已认证 Manifest、修订链	首次取得的数据仍有历史回滚限制
恶意网页钓鱼	Origin 匹配、默认用户确认、iframe 限制	用户主动向恶意站点提供密码仍可能泄露
恶意浏览器请求	Native Host 身份验证、IPC ACL、操作级授权	被攻陷的授权扩展仍有风险
恶意导入文件	字节上限、递归/深度上限、严格解析、隔离恢复	解析库漏洞需要持续维护
SSH Agent 滥用	每密钥策略、源进程/会话最小化、明确授权	通用 SSH 协议不能可靠识别全部最终主机
设备丢失	系统密钥库、生物识别、锁定策略	旧设备曾得到的 VMK 须通过完整轮换撤销
旧备份泄露	定期验证、VMK 安全重建、服务凭据轮换	不能远程擦除所有第三方副本
明文日志/崩溃转储	敏感字段脱敏、最小日志、禁采集默认	平台级转储可能含解锁时数据
剪贴板暴露	自动清理、最小驻留、提示高风险操作	OS 剪贴板历史不可统一强制清除

18.3 登录与暴力攻击策略

不提供厂商在线账户时，可以减少传统账号撞库入口，但密码重用依然危及用户在第三方网站的账号。CredPivot 不应将“能防在线撞库”混同为“离线 Vault 绝对不可暴力破解”。主密码创建时优先倡导足够长的随机词组或随机高熵字符串，支持用户可理解的强度提示；不以无意义的字符类别规则代替熵。

18.4 密钥与数据生命周期

解锁时生成的数据库密钥不得在明文日志、错误报告、系统通知、扩展持久化存储中落盘。使用操作系统保护的设备密钥和按需访问授权；明确用户的全局锁定、设备退出、睡眠唤醒后自动锁定行为。锁定不等于能清除所有 OS 或内存副本，应在技术文档里解释限制。

18.5 密码库历史删除语义

用户删除 11 条以上的旧密码记录时，当前逻辑数据库中仅保留配置的 N 条；已经生成的加密快照、Git 历史、离线副本及操作系统快照仍可能拥有较早的密文。如果用户需要让已泄露的密码失效，必须在对应网站轮换密码；如 VMK 或恢复密钥被暴露，必须执行 Vault 安全重建。

18.6 依赖、发布与供应链安全

固定加密依赖版本、开展 SBOM 清单、签名发布包、验证更新来源；依赖库与 SQLCipher 编译配置需要 CI 复现。禁止在生产构建中引入调试密钥、关闭 TLS 验证或自动上报 Vault 内秘密。重大密码学与同步协议改动需要双人审查和回归测试。

19. 非功能要求与可维护性

19.1 性能目标（需基准测试确认）

指标	初始目标	备注
数据量	10,000 条凭据基础测试集	额外构建 50,000 条压力样本
本地搜索	已解锁普通搜索 P95 < 200 ms	在约定中档设备基线测量
单条保存	本地事务用户感知 < 300 ms	不把 WebDAV RTT 计入本地成功
Vault 解锁	在安全 KDF 成本约束下可用	不能单为速度降低安全底线
内存使用	记录桌面/移动冷启动及已解锁峰值	按平台设包体和峰值预算
首次恢复	10,000 条 + 适量附件可完成	记录耗时与失败原因
同步	无冲突增量状态正确可见	时延受网络/远程服务限制
客户端体积	记录完整 Release 包实际体积	不预设 SQLite/SQLCipher 固定 MB 数

性能门槛应使用固定测试机器、网络配置和测试数据，报告中区分 P50/P95 与极端场景。不可用“没有卡顿”作为唯一验收条件。

19.2 健壮性

- 本地写入遵循 SQLite 事务；进程崩溃、异常断电、网络中断后可进行一致性恢复。
- 同步采用幂等操作 ID 与本地持久化队列，重复上传/下载不重复执行语义操作。
- 任何读取到的 Snapshot、Delta、Blob 都必须在解密使用前完成认证校验。

- 数据库升级失败不覆盖原有可用副本；客户端向后兼容策略须明确。
- 不允许静默覆盖冲突密码、TOTP 种子和 SSH 私钥。

19.3 可观测与隐私

默认禁用内容级遥测。可记录非敏感的错误码、延迟、队列长度、协议版本和 Provider 类型；任何日志不包含明文用户名、密码、URL、TOTP 种子、SSH 私钥或整个 RPC 请求载荷。向用户导出的诊断包必须提供预览与自动脱敏。

19.4 国际化和可访问性

首发支持中文简体与英文，UI 文案采用统一键值管理；日期、时间、数字、中文字体/字符宽度符合系统区域设置。对视障用户，复制密码和 OTP 按钮提供易理解的语义，不能将明文秘密无意念出；移动端大字体不应裁切紧急安全确认内容。

20. 研发实施计划、质量门禁与验收

20.1 阶段与交付物

阶段	核心产出	发布门禁
M0 规格冻结	OVB1、密码学字节规范、CXF 映射、威胁模型	两人独立按测试向量实现基本解密
M1 核心引擎	Rust Core、SQLCipher、Key Slots、恢复 CLI	崩溃恢复、密钥恢复、数据库完整性通过
M2 凭据模型	Password、History、TOTP、SSH、账号关联	功能单测与完整生命周期测试通过
M3 同步	WebDAV、Snapshot/Delta、Merge、冲突 UI	双设备并发与断网重试测试通过
M4 桌面客户端	macOS/Windows UI、Agent、SSH Agent	端到端保存、解锁、自动锁定、授权通过
M5 移动客户端	iOS/Android UI、系统填充、生物识别	沙盒/权限/后台行为真机测试通过
M6 浏览器	Chrome/Firefox/Edge/Safari 配套扩展	无 App 不可独立使用；保存/填充联动通过
M7 备份与发布	Git Push 备份、完整恢复、导入导出、审计	安全回归、可恢复演练、跨端 CI 全绿

阶段按照依赖先后排列，可以部分并行，不假设当前已有团队规模或承诺未经估算的具体工期。每阶段明确测试、Demo、版本标记与文档更新负责人。

20.2 P0 用户故事 / 验收矩阵

ID	关键场景	可验证的验收结果
AC-01	新建 Vault 并选择自定义目录	有效本地目录可创建；不选则使用默认目录
AC-02	主密码开启 Vault	正确密码可打开；错误密码不泄露记录
AC-03	恢复密钥单独解锁	无主密码仅凭完整 Vault + 恢复密钥可恢复
AC-04	非原应用恢复	独立 CLI 能导出密码、TOTP、SSH；公开测试向量通过
AC-05	指纹/Face ID/Hello 解锁	系统安全存储授权生效，新设备仍需通用解锁
AC-06	修改密码	更新时间正确；旧密码进入最近 N 条历史
AC-07	90 天提醒	依据真实启用时间提醒；不强制修改；可覆盖/关闭
AC-08	TOTP	与 RFC 6238 向量一致；倒计时/离线可用
AC-09	SSH Agent	授权策略内签名成功，越权请求被拒绝
AC-10	三模块联动	GitHub 账号关联密码、TOTP、SSH，入口可直达
AC-11	WebDAV 离线 Outbox	断网保存不丢；重连后自动幂等上传
AC-12	双端同密码冲突	两个版本都保留，用户可选择并形成新修订
AC-13	删除与长期离线	Tombstone 不被旧设备无意复活
AC-14	浏览器依赖安装	未安装 App 不能查看、保存或同步任何 Vault 秘密
AC-15	浏览器创建账号	本地事务提交后桌面 UI 即可看见，云同步分状态显示
AC-16	移动系统填充	按系统权限可调用，并按 Origin/身份规则限制
AC-17	Git 备份	仅 Push 加密归档，不能静默执行 Git Merge 或强推
AC-18	提供商迁移	WebDAV → 另一 OVB 目录，不依赖数据库原文件格式

ID	关键场景	可验证的验收结果
AC-19	篡改密文对象	AEAD / 哈希链校验失败，禁止伪装成功
AC-20	SQLCipher 临时文件	测试未发现可恢复的持久化明文秘密副本
AC-21	Vault 目录迁移失败	原 Vault 仍可安全打开，没有被覆盖
AC-22	UI 可访问性	主要任务支持键盘、屏幕阅读器与大字体
AC-23	备份恢复演练	隔离恢复与完整性校验成功后才显示已验证

20.3 安全测试体系

1. **密码学测试**：Argon2id、HKDF、AES-GCM、SQLCipher 原始密钥参数、不同 Slot 解锁、错误 nonce/AAD、篡改/截断/重排输入、测试向量跨实现一致。
2. **协议 Fuzz**：OVB Header、CBOR/JSON、Snapshot/Delta、附件路径、深层嵌套、超大字段、恶意 KDF 参数、随机字节解析。
3. **并发与故障注入**：两设备同时修改、上传中途断线、ETag 冲突、重复包、上传成功但本地未记 ACK、列表延迟、旧设备重连、移动设备休眠。
4. **数据库测试**：事务回滚、WAL 恢复、Schema 迁移回滚、备份一致性、重复解锁/关闭、数据库损坏检测。[R04][R05]
5. **浏览器安全测试**：恶意 Origin、子域混淆、跨域 iframe、内容脚本伪造消息、扩展卸载/重装、Agent 假冒、页面 DOM 变动。
6. **SSH 安全测试**：未授权签名、重复授权会话、Agent IPC 权限、Host Key 更换、导入恶意格式、私钥导出时二次确认。
7. **恢复测试**：只保留 OVB 加密归档和主密码、只保留恢复密钥、丢失单个 Delta、Snapshot 回滚、Git 旧历史安全重建、损坏附件报告。
8. **多平台联测**：桌面/手机真实硬件、系统生物识别变更、沙盒目录、浏览器 Native Host 生命周期与 Release 包签名。

20.4 研发治理与评审

核心协议采用 ADR（Architecture Decision Record）管理；对加密参数修改、删除语义、设备撤销和 Provider 一致性能力实行强制双人评审。合并生产分支前执行静态检查、单测、平台编译、密码学测试向量与必要的模拟网络故障。发布候选需要复核公开协议文档与独立恢复 CLI 均可使用。

21. 风险清单与待实现前评审事项

风险等级	事项	处理决定
严重	主密码过弱导致离线猜测	高熵教育、KDF 实测、明确不可绝对防御

风险等级	事项	处理决定
严重	Key Slot 更新与旧历史泄露	区分普通改密和完整 VMK 轮换
严重	不完整远程列举导致漏同步	WebDAV 兼容性门槛、设备链缺口检测
严重	备份损坏但 UI 误报成功	独立恢复演练与完整性校验
高	多端同字段修改覆盖	父修订冲突检测与人工解决
高	移动外部目录不支持 WAL	沙盒工作数据库 + 独立归档位置
高	浏览器没有安装配套 App	扩展拒绝独立存储、明确连接引导
高	原生 Agent 进程被滥用	配对、签名源/会话授权、IPC ACL
中	SQLCipher 二进制增大安装包	各平台 Release 真机基准、精简依赖
中	OVB 格式前向兼容失败	版本规则、迁移器、跨实现向量
中	Git 旧提交导致备份膨胀	单写入端、体积提示、新仓库重建策略
中	UI 密码历史时间误导	生成时间、启用时间与修改时间分开

实现前需要冻结而非要求用户反复确认的技术事项：OVB 字节编码选型、对象 AEAD 子密钥算法与 AAD、设备链的具体签名/MAC 模型、SQLCipher 编译参数、Provider 最低对象发现能力、TOTP 格式映射、CXF 不支持字段的导出策略、各平台备份目录权限和可信根/防回滚边界。这些应形成独立小型协议文件、测试向量和安全评审记录，不阻碍本文件作为产品与总体架构基线。

附录 A. 数据结构与接口示例

A.1 Item 和 Credential（解密后的逻辑样例）

以下示例只说明**应用内明文逻辑结构**，绝不可作为业务 JSON 写入未加密持久化目录。

```
{
  "item_id": "random-item-id",
  "title": "GitHub / Work",
  "type": "account",
  "urls": ["https://github.com"],
  "credentials": [
    {
      "id": "login-01",
```

```
      "type": "basic-auth",
      "username": "user@example.com",
      "password": "<secret>",
      "password_generated_at": "2026-10-01T10:00:00Z",
      "password_activated_at": "2026-10-02T11:00:00Z",
      "history_limit": 10
    },
    { "id": "totp-01", "type": "totp", "secret": "<secret>" },
    { "id": "ssh-01", "type": "ssh-key", "key_ref": "<opaque-ref>" }
  ]
}
```

A.2 Vault Key Slot 结构草案

以下示例仅表示字段意图，不是可直接发布的字节级密码学规范。

```
{
  "magic": "OVB1",
  "format_major": 1,
  "vault_id": "<random-id>",
  "key_slots": [
    {
      "slot_id": "<random-id>",
      "type": "master-password",
      "kdf": "argon2id",
      "memory_kib": 65536,
      "iterations": 3,
      "parallelism": 4,
      "salt": "<base64url>",
      "nonce": "<base64url>",
      "wrapped_vmk": "<base64url>"
    },
    {
      "slot_id": "<random-id>",
      "type": "recovery-key",
      "kdf": "hkdf-sha256",
      "salt": "<base64url>",
      "nonce": "<base64url>",
      "wrapped_vmk": "<base64url>"
    }
```

```
  ]
}
```

A.3 Delta 结构草案

```
{
  "op_id": "<random-id>",
  "device_id": "<random-device-id>",
  "device_seq": 42,
  "prev_device_op_hash": "<hash>",
  "record_id": "<opaque-record-id>",
  "parents": ["rev-41"],
  "action": "credential.update",
  "revision_id": "rev-42",
  "timestamp_utc": "2026-10-15T00:00:00Z",
  "payload": { "<encrypted-inner-field>": "<value>" }
}
```

该结构整体放置于**经过 OVB 认证加密的 Delta 密文内**。timestamp_utc 仅供显示和审计，不能单独决定冲突合并顺序。设备序号与链摘要负责检测缺失、重复、顺序异常；具体字节规范见后续 sync-v1.md。

A.4 Native Host 操作示例

```
{
  "protocol_version": 1,
  "request_id": "<random-request-id>",
  "action": "credential.suggest_for_origin",
  "origin": "https://github.com",
  "frame_context": "top-level",
  "session_ref": "<opaque-authorized-session>"
}
```

Native Host 必须以浏览器实际提供的扩展来源、受信任连接与浏览器框架信息交叉核验用户上报的 Origin。消息体携带的字符串本身不构成可信身份依据；绝不提供 vault.export_all_secrets 一类可以让普通内容脚本枚举全库的权限。

A.5 SQLCipher 表结构示意

```
CREATE TABLE credentials (
    id TEXT PRIMARY KEY,
    item_id TEXT NOT NULL,
    kind TEXT NOT NULL,
    payload BLOB NOT NULL,
```

```
    current_revision TEXT NOT NULL,
    created_at_utc INTEGER NOT NULL,
    updated_at_utc INTEGER NOT NULL
);

CREATE TABLE password_history (
    id TEXT PRIMARY KEY,
    credential_id TEXT NOT NULL,
    secret BLOB NOT NULL,
    generated_at_utc INTEGER,
    activated_at_utc INTEGER,
    retired_at_utc INTEGER,
    FOREIGN KEY (credential_id) REFERENCES credentials(id)
);

CREATE TABLE sync_outbox (
    op_id TEXT PRIMARY KEY,
    device_id TEXT NOT NULL,
    device_seq INTEGER NOT NULL,
    sealed_delta BLOB NOT NULL,
    upload_state INTEGER NOT NULL,
    created_at_utc INTEGER NOT NULL
);
```

payload/secret 所在数据库本身由 SQLCipher 加密；是否在内层再做字段级加密留给敏感访问控制和安全审计评估，V1 不因“已经用 BLOB”便误称字段独立加密。上述 DDL 是逻辑示例，正式生产 Schema 需要主外键、索引、状态枚举、修订一致性和迁移测试。

附录 B. 标准、公开规范与参考资料

下列参考资料主要用于确认设计边界与实现约束。标记为“参考”的公开规范不代表 CredPivot 自动获得认证、符合某标准或具备相应完整实现。

编号	公开资料	设计用途
R01	FIDO CXF 1.0 Proposed Standard + Errata	Item/Credential 模型与互导参考
R02	RFC 9106 Argon2	主密码内存困难派生参数参考
R03	SQLCipher Design / API	本地页面加密、原始密钥、临时文件策略
R04	SQLite WAL	本地事务/多进程/非网络数据库限制

编号	公开资料	设计用途
R05	SQLite Online Backup API	一致性数据库备份原则
R06	NIST SP 800-63B-4	周期改密不应强制的安全依据
R07	RFC 6238	TOTP 生成与参数
R08	RFC 4918	WebDAV、ETag 与并发控制
R09	AWS S3 Conditional Writes	S3 后续适配器能力约束
R10	Chrome Native Messaging	扩展与本机 Host 的通信及来源校验
R11	Android Credential Provider	Android 系统填充与凭据提供
R12	Apple AutoFill Credential Provider	iOS / macOS 系统集成
R13	KeePass KDBX 4.1	成熟加密保险库兼容格式
R14	Google Drive App Data	云端可见目录与隐藏目录的取舍
R15	WCAG 2.2	UI 无障碍验收依据
R16	GitHub Removing sensitive data	Git 历史中的秘密移除风险

官方链接（截至 2026-10-15）

- [R01] FIDO Alliance · Credential Exchange Format 1.0
- [R02] IETF · RFC 9106 (Argon2)
- [R03] Zetetic · SQLCipher Design；SQLCipher API
- [R04] SQLite · WAL
- [R05] SQLite · Online Backup API
- [R06] NIST · SP 800-63B-4
- [R07] IETF · RFC 6238 (TOTP)
- [R08] IETF · RFC 4918 (WebDAV)
- [R09] AWS · S3 Conditional Writes
- [R10] Chrome · Native Messaging
- [R11] Android · Credential Provider
- [R12] Apple · ASCredentialProviderViewController
- [R13] KeePass · KDBX File Format
- [R14] Google Drive · AppDataFolder
- [R15] W3C · WCAG 2.2
- [R16] GitHub · Removing Sensitive Data